ContextKeeper WP-007: Compliance, distribution, and ecosystem research brief

An AI developer governance platform entering the enterprise market in 2026 faces a regulatory landscape that is rapidly crystallizing but still contains navigable gaps. The SOC 2 framework remains stable on the 2017 Trust Services Criteria, the EU AI Act's high-risk provisions won't fully apply until August 2026 (and may slip to late 2027), MCP has achieved near-universal adoption under Linux Foundation governance, and the AI governance platform market is projected to reach **$492M in 2026** per Gartner's most authoritative estimate. This brief covers all five research domains with maximum precision as of March 2026.

SOC 2 Type II: the criteria haven't changed since 2022

The operative standard remains the **"2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus — 2022)"**, designated TSP Section 100 and published by AICPA's Assurance Services Executive Committee. The 2022 revision updated points of focus — non-prescriptive guidance addressing evolving threats, privacy regulations, and data controller/processor distinctions — but left the **underlying criteria text unchanged**. Linford Co No new TSC version has been released or publicly announced, and no exposure drafts are pending. The AICPA did release an updated SOC 2 Audit Guide (the first major guidance update since 2018), but this is auditor guidance, not a criteria revision. KSM EY

The nine Common Criteria (CC) series remain the mandatory Security category backbone, Bright Defense mapping CC1–CC5 to the 17 COSO 2013 principles and CC6–CC9 as supplemental control activities: Linford Co

CC Series	Official name	Sub-criteria
CC1	Control Environment	CC1.1–CC1.5
CC2	Information and Communication	CC2.1–CC2.3
CC3	Risk Assessment	CC3.1–CC3.4
CC4	Monitoring Activities	CC4.1–CC4.2
CC5	Control Activities	CC5.1–CC5.3
CC6	Logical and Physical Access Controls	CC6.1–CC6.8
CC7	System Operations	CC7.1–CC7.5
CC8	Change Management	CC8.1
CC9	Risk Mitigation	CC9.1–CC9.2

Note that **Availability is a separate optional TSC category** (criteria A1.1–A1.3), not a CC series. It supplements the Common Criteria but must be explicitly included in the SOC 2 scope. Cloud Security Alliance Drata CC3 covers Risk Assessment, CC6 covers Logical and Physical Access Controls, CC7 covers System Operations, CC8 covers Change Management, and CC9 covers Risk Mitigation Secureframe — confirming the identifiers in the WP-007 document.

Timeline, cost, and common audit gaps for startup SaaS

A first-time SOC 2 Type II for an early-stage SaaS company typically takes **6–12 months end-to-end**: Drata 2–4 weeks for scoping, Cgcompliance 1–3 months for gap remediation, TheSOC2 a mandatory 3–12 month observation window (minimum 3 months for first Type II, though 6 months is recommended), Secureframe 4–6 weeks for audit fieldwork, Secureframe and 3–4 weeks for report finalization. Cgcompliance Many startups compress the

path by achieving Type I first (Comp AI) (1.5–3.5 months), then transitioning to Type II with a 3–6 month observation window starting the day after the Type I date. (EasyAudit)

First-year costs for a Security-only Type II range from **$30,000–$100,000**, (TheSOC2) broken down as: audit fees ($15K–$50K depending on firm size), compliance automation platform ($6K–$30K/year (TheSOC2) for Vanta, Drata, Secureframe, or Sprinto), readiness assessment ($10K–$25K), penetration testing ($5K–$25K), and policy development ($5K–$10K). Renewal costs drop to approximately **$20K–$40K annually**. (TheSOC2) These figures come from vendor-produced sources with potential marketing bias, but are corroborated across 8+ independent estimates.

The most frequently cited control gaps in early-stage SaaS audits are remarkably consistent across CPA firm data and compliance platforms:

- **Untimely user deprovisioning** (CC6.2/CC6.3) — former employees retain system access beyond policy SLAs, the single most common exception (Schneider Downs)
- **Missed quarterly access reviews** (CC6.1/CC6.3) — reviews documented but not all actually performed (Sprinto)
- **Excessive privileged access** (CC6.3) — engineers with unnecessary root/admin access from early-stage growth (Bastion)
- **Missing change management approvals** (CC8.1) — code deployed without documented peer review or pre-production testing (Schneider Downs)
- **Incomplete security training and policy acknowledgments** (CC1.4/CC2.2) — no tracking mechanism or formal sign-off workflow (Schneider Downs)
- **Vendor risk management gaps** (CC9.2) — subprocessors not formally assessed (Bastion)
- **Untested backup/DR plans** (CC7.4/A1.2) — backups exist but restoration never validated (Bastion)

A key insight from Bastion (February 2026): "Most exceptions stem from missing documentation, not missing controls." Bastion Controls often exist and operate, but evidence was not systematically captured.

Confidence: HIGH for criteria identifiers and version status (confirmed from AICPA official sources). **MEDIUM-HIGH** for cost/timeline ranges (well-corroborated but highly variable by organization).

EU AI Act: governance tools likely escape high-risk classification

The EU AI Act (Regulation (EU) 2024/1689) was **published in the Official Journal on 12 July 2024** White & Case LLP and **entered into force on 1 August 2024.** Cyber Risk GmbH It follows a phased implementation schedule that, as of March 2026, looks like this:

Already in force: Prohibited AI practices and AI literacy obligations (since 2 February 2025); GPAI model obligations, governance rules, notifying authorities, and the penalty regime (since 2 August 2025). Cyber Risk GmbH

Upcoming: The bulk of remaining obligations — high-risk AI system requirements for Annex III systems, transparency obligations under Article 50, and GPAI-specific penalties — take effect **2 August 2026.** European Commission However, the Commission's **Digital Omnibus on AI** (proposed 19 November 2025) would delay high-risk obligations liea to **2 December 2027** for Annex III systems and **2 August 2028** for Annex I product-embedded systems, contingent on harmonized standards availability. Passle Trilogue negotiations are expected April–May 2026. Tech Law Blog Until enacted, the original August 2026 deadline applies. The Commission also **missed its 2 February 2026 deadline** for publishing Article 6 guidelines with practical high-risk classification examples; it indicated it planned to publish a final draft by end of February 2026. IAPP

Classification framework and ContextKeeper's likely position

The Act establishes four risk tiers: Unacceptable (prohibited, Article 5), High-Risk (Articles

6, Annexes I and III), Limited/Transparency Risk (Article 50), and Minimal/No Risk (unregulated). High-risk classification follows two pathways: Article 6(1) for AI systems that are safety components of products covered by Annex I harmonization legislation, and Article 6(2) for systems falling within one of eight Annex III categories Europa (biometrics, critical infrastructure, education, employment, essential services, law enforcement, migration, and justice).

An AI governance/session management platform like ContextKeeper would very likely NOT qualify as high-risk. It is not a safety component of Annex I regulated products, and none of the eight Annex III categories cover internal developer tooling, AI session management, or software development governance. The categories focus on decisions affecting natural persons' fundamental rights — biometric identification, employment decisions, credit scoring, law enforcement, and similar domains. A developer tool would most likely be classified as **minimal risk** or, if it presents AI-generated content, subject only to limited transparency obligations under Article 50.

Critical caveat: If the platform were used to evaluate developer performance for HR decisions, it could fall into Annex III category 4 (employment). This edge case should be addressed in product positioning and terms of service.

Technical documentation and GPAI wrapper obligations

Articles 11 and 13 apply only to high-risk AI systems. Article 11 requires technical documentation per Annex IV EU Artificial Intelligence Act covering nine mandatory sections: general description, development process and design, monitoring/functioning/control measures, performance metrics, risk management system, lifecycle changes, applied standards, EU declaration of conformity, and post-market monitoring plan. Retention is **10 years** from market placement. aiacto Article 13 mandates sufficient transparency for deployers to interpret system output, accompanied by detailed instructions for use covering provider identity, capabilities/limitations, accuracy levels, known risks, input specifications, human oversight measures, and logging mechanisms. Europa

For companies that **wrap GPAI models** (as ContextKeeper would, integrating Claude, GPT, or similar), the distinction is critical: **simply fine-tuning, prompting, or integrating a GPAI model via API does not make a downstream company a GPAI model provider.** The wrapper company is classified as an AI system provider subject to risk-based obligations under Articles 5, 16–27, and 50 depending on risk classification — not subject to Chapter V GPAI provider obligations (Articles 53–56), which fall on foundation model developers like Anthropic and OpenAI. EU Artificial Intelligence Act A downstream actor only becomes a GPAI provider if they make a "substantial modification" European Commission (indicative threshold: modification training compute exceeds one-third of original model's training compute) European Commission or put their name/trademark on a high-risk system already on market.

Confidence: HIGH for publication dates, classification framework, and GPAI distinction (confirmed from statutory text and multiple law firm analyses). **MEDIUM** for Digital Omnibus timeline (proposal exists but adoption uncertain).

HIPAA BAA: AI session logs are almost certainly PHI

Technical safeguards under 45 CFR §164.312

The HIPAA Security Rule's technical safeguards comprise five standards: Access Control (§164.312(a)), Audit Controls (§164.312(b)), Integrity (§164.312(c)), Person or Entity Authentication (§164.312(d)), and Transmission Security (§164.312(e)). AccountableHQ For SaaS vendors, the practical requirements translate to: **AES-256 encryption at rest**, **TLS 1.2+ in transit** (industry standard now TLS 1.3), role-based access control with unique user identifiers, AccountableHQ multi-factor authentication, automatic session logoff, AccountableHQ comprehensive tamper-evident audit logging with 6-year retention, and multi-tenancy isolation.

The distinction between "required" and "addressable" safeguards is frequently misunderstood. "Addressable" does not mean optional — it requires implementation unless a documented risk assessment justifies an alternative or determines it unnecessary.

AccountableHQ For SaaS vendors, **encryption is effectively mandatory** because PHI traverses non-private networks with no reasonable alternative in cloud contexts. HIPAA Journal

A January 2025 HHS Notice of Proposed Rulemaking would eliminate the required/addressable distinction entirely, making all safeguards mandatory, and would add explicit requirements for MFA, network segmentation, annual technology asset inventories, vulnerability scanning, penetration testing, 72-hour system restoration capability, Kiteworks and **24-hour breach notification** from business associates to covered entities Chesshealthsolutions (currently 60 days). This NPRM is **not yet finalized** as of March 2026 and faces significant industry opposition. HIPAA Journal

AI session logs and PHI classification

AI session logs and governance audit trails almost certainly constitute PHI when the underlying sessions involve healthcare data. PHI is defined at 45 CFR §160.103 as individually identifiable health information — created or received by a covered entity or business associate, relating to health conditions or healthcare provision, and identifying (or reasonably capable of identifying) the individual. HIPAA Journal When AI sessions capture user inputs containing patient names, conditions, or treatment queries alongside identifiers like user IDs, IP addresses, and timestamps, the logs contain both health information and identifiers, making them definitively PHI.

Even metadata can qualify: "User X queried about condition Y at time Z" constitutes PHI if the user can be identified and the query relates to healthcare. HHS has stated that cloud service providers have "persistent access" to PHI even under zero-knowledge models. HIPAA Journal Academic literature (Rezaeikhonakdar, 2024, *Journal of Law, Medicine & Ethics*) confirms that when healthcare providers input patient data into AI tools, the AI vendor becomes a business associate and session logs inherit PHI status. nih Governance audit trails recording who accessed what PHI, when, and what actions were taken also contain sufficient information to qualify as PHI.

De-identification via Safe Harbor (removing all 18 HIPAA identifiers) or Expert Determination methods can remove PHI status from session data before analysis, but must be validated for the specific AI use case. Keragon Tadabase

Indemnification structure and hosting configurations

HIPAA does not require indemnification clauses in BAAs Outside GC Foxrothschild — the HHS sample BAA provisions are silent on the topic. In practice, most covered entities impose **one-sided indemnification** on the business associate Outside GC covering breaches, BAA violations, negligence, and costs of patient notification and credit monitoring. Association of Corporate C... Bmdllc Mutual indemnification is negotiated when the BA has leverage. **There is no standard liability cap** — terms are heavily negotiated. Bmdllc Uncapped indemnification for breach is common in healthcare per Aptible's analysis. Aptible Some agreements use a "super cap" approach with a low general cap but higher data breach cap. Bmdllc Cyber insurance requirements typically range from **$2M–$10M** per occurrence. Aptible Virginia

Breach notification must occur "without unreasonable delay and in no case later than **60 calendar days**" after discovery (45 CFR §164.410), though most BAAs contractually shorten this to 2–30 days. Bmdllc The proposed 2025 NPRM would require 24-hour notification.

On hosting: **Standard cPanel shared hosting is NOT HIPAA-eligible.** Major shared hosting providers (Bluehost, GoDaddy) explicitly disclaim HIPAA compliance and refuse to sign BAAs. Bluehost Shared environments cannot guarantee resource isolation, granular access controls, or physical/logical separation of ePHI. AccountableHQ **Dedicated hosting and BYOI (Bring Your Own Infrastructure) are HIPAA-eligible** with proper configuration. All three major cloud providers — AWS (120+ HIPAA-eligible services), Azure, and GCP — offer HIPAA-eligible configurations under signed BAAs. Liquid Web AWS notably dropped its dedicated instance requirement in 2017; any EC2 instance size now qualifies.

Confidence: HIGH for technical safeguards, PHI classification analysis, and hosting eligibility (confirmed from statutory text and multiple authoritative sources). **MEDIUM** for

indemnification norms (highly variable in practice).

MCP ecosystem: universal adoption under Linux Foundation governance

MCP has achieved extraordinary adoption since Anthropic's November 2024 launch. Thoughtworks As of early 2026, it counts **97+ million monthly SDK downloads**, Gupta Deepak **10,000+ active published servers**, and support from essentially every major IDE and AI client. Modelcontextprotocol On **9 December 2025**, Anthropic donated MCP to the **Agentic AI Foundation (AAIF)**, a directed fund under the Linux Foundation, Modelcontextprotocol co-founded by Anthropic, Block, and OpenAI. Linux Foundation Wikipedia

Adoption across IDEs and AI clients

Every major development environment now supports MCP: **VS Code** (via GitHub Copilot agent mode), **Cursor** (native MCP in settings), Plain Cursor **JetBrains IDEs** (dual client/server support in 2025.1/2025.2), MCP Stack **Windsurf**, **Zed**, **Replit**, Wikipedia and Amazon **Kiro**. On the AI client side, **Claude Desktop and Claude Code** provide first-class support, Plain **ChatGPT** adopted MCP across its Agents SDK and Responses API in March 2025 Wikipedia and launched an MCP-powered App Store in December 2025, Wikipedia **GitHub Copilot** integrates MCP through VS Code's agent mode (Microsoft joined the MCP steering committee at Build 2025), Wikipedia and **Google Gemini** confirmed MCP support in April 2025. Pento Platform integrations include Cloudflare (hosted MCP server deployment), Wikipedia Salesforce Agentforce, Atlassian Rovo (Jira/Confluence), GitHub and all three major cloud providers.

Governance, licensing, and standardization status

MCP is an **open standard** GitHub Model Context Protocol licensed under **MIT** (specification and original SDKs) with newer SDKs transitioning to **Apache 2.0**. The AAIF Governing Board handles strategic decisions while MCP **maintains full technical autonomy** through its maintainers and the SEP (Specification Enhancement Proposal) process. Modelcontextprotocol David Soria Parra serves as Lead Core Maintainer. Modelcontextprotocol

Platinum AAIF members include AWS, Anthropic, Block, Bloomberg, Cloudflare, Google, Microsoft, and OpenAI. Gold members include Cisco, Datadog, Docker, IBM, JetBrains, Oracle, Salesforce, SAP, Shopify, Snowflake, and Twilio. Block

MCP has **not been submitted to any formal standards body** (IETF, W3C, or similar). It operates under the Linux Foundation model — similar to how Kubernetes (CNCF) and PyTorch are governed — rather than through formal standardization processes. GitHub The latest specification version is **2025-11-25** (released as RC), adding asynchronous operations, statelessness, server identity, and a community-driven registry. Pento

Competing protocols are complementary, not competing

The emerging protocol landscape positions MCP as the **vertical** standard (agent-to-tools/data) alongside complementary horizontal protocols:

- **Google A2A** (Agent-to-Agent, April 2025, now Linux Foundation-hosted): Agent-to-agent communication IBM with 50+ launch partners. Google explicitly states A2A "complements" MCP. DataCamp Google Developers Notably, Anthropic and OpenAI were not among initial partners. Koyeb
- **IBM ACP** (Agent Communication Protocol, May 2025): Agent-to-agent messaging within managed environments, built initially on MCP. IBM Pre-alpha/alpha stage, primarily within IBM's BeeAI ecosystem. IBM
- **AG-UI** (CopilotKit): Standardizes agent-to-frontend connections. Supported by LangGraph, CrewAI, Google ADK. Medium

None of these protocols compete directly with MCP's core function. DataCamp +2 MCP's adoption is orders of magnitude ahead, and its Linux Foundation governance with backing from all major AI companies gives it **effective monopoly status** in the agent-to-tool connectivity layer.

Confidence: HIGH for adoption status, governance, and licensing (confirmed from Linux Foundation press releases, official MCP blog, and GitHub repositories). **HIGH** for

competitive protocol positioning.

AI governance market: $492M in 2026, accelerating fast

Gartner's February 2026 press release provides the most authoritative market sizing: **$492M in AI governance platform spending by 2026**, growing to **over $1 billion by 2030**. Gartner Third-party research firms place the 2024 baseline at $200M–$300M with consensus CAGR of **35–45%** through 2030, though estimates vary widely by market definition — broader "AI governance and compliance" categories reach $2.5B+ when including AI-powered compliance tools generally.

All three major analyst firms have published dedicated evaluations

Gartner published its first **Market Guide for AI Governance Platforms** in November 2025 (analysts: Lauren Kornutick, Sumit Agarwal, Avivah Litan, Svetlana Sicular), defining the category and profiling representative vendors. Gartner It also published a Market Guide for AI TRiSM (February 2025) and a Magic Quadrant for Data & Analytics Governance Platforms (January 2026, Ataccama with IBM, Informatica, IBM Alation, Alation and Atlan as Leaders). Atlan No dedicated AI Governance MQ exists yet, but the Market Guide typically precedes an MQ by 1–2 years.

Forrester published **The Forrester Wave: AI Governance Solutions, Q3 2025** CIO Dive — the first full competitive evaluation of the category. Forrester Credo AI claims Wave Leader status. Credo AI Forrester also predicts **60% of Fortune 100 will appoint a head of AI governance in 2026.** CIO Dive

IDC published the most comprehensive evaluation: the **IDC MarketScape: Worldwide Unified AI Governance Platforms 2025-2026** (December 2025), evaluating **20 vendors**. IDC Leaders include Microsoft, IBM (watsonx.governance), and Databricks. Other evaluated vendors include Credo AI, SAS, ServiceNow, FairNow, Fairly AI, Dataiku, AWS, DataRobot, and Coralogix. IDC

Competitive landscape for AI agent governance and audit trails

The market is bifurcating into four segments relevant to ContextKeeper:

Pure-play AI governance platforms — Credo AI (pioneer, customers include Mastercard, Credo AI Cisco, Disney; Credo Andrew Ng-backed), ModelOp (lifecycle automation for regulated industries), Yahoo Finance Trustible (operationalizing governance, Gartner-recognized), Trustible LatticeFlow AI (ETH Zurich/INSAIT spinout, EU AI Act evaluation), Latticeflow Holistic AI (bias testing), and FairNow.

AI agent security and governance (fastest-growing) — Noma Security ($100M Series B in July 2025, Noma Security **1,300% ARR growth** in first year), Noma Security Zenity (purpose-built for AI agent security, Crunchbase Microsoft M12-backed, PitchBook Forrester-recognized), Zenity Oasis Security (Cursor IDE partnership for developer-facing agent governance), Oasis and Airia (launched AI Governance product January 2026). Airia

Platform vendors adding governance — IBM watsonx.governance MarketsandMarkets (IDC Leader), IBM Microsoft Purview/Foundry (IDC Leader), Microsoft Azure Microsoft Databricks Unity Catalog (IDC Leader for strategy), Databricks OneTrust, OneTrust ServiceNow, Dataiku, and Collibra.

AI observability/LLMOps (adjacent, developer-focused) — Arize AI ($70M Series C, February 2025), Maxim Articles Galileo AI ($68M total funding), Maxim Articles LangSmith (LangChain ecosystem), o-mega Langfuse (open-source, o-mega popular for self-hosting in regulated industries), Maxim Articles Weights & Biases ($250M+ raised, ~$1.25B valuation), Helicone, and Maxim AI.

Notable M&A: Cisco acquired Robust Intelligence PitchBook for approximately **$400M** in September 2024, BankInfoSecurity Crunchbase integrating it into Cisco Security Cloud as "Cisco AI Defense." Cisco Blogs

The specific niche of **AI session management and developer audit trails** — ContextKeeper's core territory — sits at the intersection of agent governance and observability but lacks dedicated analyst coverage. Oasis Security's Cursor partnership

Oasis and Langfuse's regulated-industry adoption are the closest competitive proxies, suggesting the niche is emerging but underserved.

Confidence: HIGH for Gartner market sizing, analyst report existence, and major funding rounds. **MEDIUM** for third-party research firm estimates (directional but varying). **LOW** for projections beyond 2030.

Conclusion

Five strategic insights emerge from this research. First, **compliance timing is favorable**: the SOC 2 framework is stable Linford Co and well-understood, the EU AI Act's high-risk obligations likely won't apply to developer tools (and may slip to late 2027 via the Digital Omnibus), European Commission and HIPAA eligibility is achievable with proper architecture — but requires abandoning shared hosting entirely. Second, **MCP's governance transition to the Linux Foundation removes a major adoption risk** for any platform building on the protocol; it is now vendor-neutral with backing from every major AI company. Modelcontextprotocol +2 Third, **the AI governance market has institutional validation** from all three major analyst firms, with Gartner projecting the category will double to $1B+ by 2030. Gartner Fourth, **the developer-focused AI governance niche is genuinely underserved** — existing competitors cluster around enterprise AI risk management or LLM observability, with very few addressing session-level governance and audit trails for individual developer workflows. Fifth, the **HIPAA BAA pathway requires explicit architectural decisions**: BYOI or dedicated cloud configurations, not shared hosting; AccountableHQ session logs must be treated as PHI by default when healthcare customers are involved; and indemnification terms will be heavily negotiated with no standard template to rely on. Bmdllc